SENTINEL APPSEC | APPLICATION SECURITY VERIFICATION

http://youtube.com/

Report ID: sentinel-audit-1794155958445 | Duration: 14507 ms

Date: Sun, 08 Nov 2026 16:39:18 GMT | URL: http://youtube.com/

CRITICAL	HIGH	MEDIUM	LOW	PASSED
0	1	2	2	8

1. Executive Verification Summary

The Sentinel AppSec engine verified 5 security finding(s) backed by empirical HTTP header responses, SPA-filtered sensitive route probes, live OSV.dev CVE advisories, or exact source code line matches, alongside 8 passed security control(s).

2. Empirical Vulnerability Ledger (5)

01. [HIGH] Unencrypted HTTP Transport (Missing TLS/HTTPS)

CWE-319 | A02:2021 Cryptographic Failures | Target: http://youtube.com/

Summary: The target endpoint was served over unencrypted HTTP without HTTPS encryption.

Impact: Network intermediaries can intercept session tokens and payloads in transit.

```
Protocol: HTTP (Plaintext)
```

Remediation: Enforce automatic HTTPS redirection and install a valid TLS certificate.

02. [MEDIUM] Missing Content-Security-Policy (CSP) Header

CWE-693 | A05:2021 Security Misconfiguration | Target: http://youtube.com/

Summary: Neither the HTTP response headers nor HTML <meta> tags define a Content-Security-Policy.

Impact: Without a restrictive CSP, any Cross-Site Scripting (XSS) flaw or rogue third-party script can execute arbitrary JavaScript and exfiltrate user tokens to external domains.

```
GET http://youtube.com/ -> HTTP 200
content-security-policy: <ABSENT>

Actual Response Headers:
server: GitHub.com
access-control-allow-origin: *
strict-transport-security: max-age=31556952
content-type: text/html; charset=utf-8
```

Remediation: Configure a strict Content-Security-Policy header restricting script-src, object-src, and frame-ancestors.

03. [MEDIUM] Missing Clickjacking Protection (X-Frame-Options / frame-ancestors)

`CWE-1021 | A05:2021 Security Misconfiguration | Target: http://youtube.com/`

Summary: Neither X-Frame-Options nor CSP frame-ancestors is present on the HTTP response.

Impact: Malicious external sites can embed this application inside an invisible <iframe> and trick students into clicking authenticated buttons (UI Redressing / Clickjacking).

```
x-frame-options: <ABSENT>
content-security-policy frame-ancestors: <ABSENT>

Actual Response Headers:
accept-ranges: bytes
access-control-allow-origin: *
age: 0
cache-control: max-age=600
```

Remediation: Set X-Frame-Options to DENY or SAMEORIGIN and add frame-ancestors 'none' to your Content-Security-Policy.

04. [LOW] Missing X-Content-Type-Options: nosniff Header

`CWE-16 | A05:2021 Security Misconfiguration | Target: http://youtube.com/`

Summary: The server does not send X-Content-Type-Options: nosniff, allowing browsers to MIME-sniff response bodies.

Impact: Browsers may interpret user-uploaded text or image files as executable HTML or JavaScript.

```
x-content-type-options: <ABSENT>

Actual Response Headers:
accept-ranges: bytes
access-control-allow-origin: *
age: 0
cache-control: max-age=600
connection: keep-alive
```

Remediation: Send X-Content-Type-Options: nosniff on all HTTP responses.

05. [LOW] Permissive Wildcard CORS Policy (Access-Control-Allow-Origin: *)

`CWE-942 | A05:2021 Security Misconfiguration | Target: http://youtube.com/`

Summary: The endpoint returns Access-Control-Allow-Origin. *, permitting any external origin to read public response data via fetch/XHR.

Impact: If applied globally to authenticated or internal API routes, untrusted origins may read sensitive application responses.

```
Access-Control-Allow-Origin: *
```

Remediation: Restrict Access-Control-Allow-Origin to explicit trusted origins unless the endpoint is intentionally a public read-only API.

3. Verified Passed Security Controls (8)

[PASS] **Framework Fingerprinting Headers (X-Powered-By) Suppressed (http://youtube.com/)**
`x-powered-by header absent and server version masked`

[PASS] **Subresource Integrity (SRI) / Local Script Origin Verified (http://youtube.com/)**
`Inspected 1 script tag(s); 0 unverified external scripts found`

[PASS] **Sensitive Route Protected (/.env) (http://youtube.com/.env)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Sensitive Route Protected (/.git/config) (http://youtube.com/.git/config)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Sensitive Route Protected (/assets/index.js.map) (http://youtube.com/assets/index.js.map)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **HTTP Verb & TRACE Restriction Verified (http://youtube.com/)**
`OPTIONS check completed; TRACE disabled`

[PASS] **GraphQL Unauthenticated Introspection Protected (http://youtube.com//graphql)**
`Probed /graphql and /api/graphql - no unauthenticated schema dump exposed`

[PASS] **URL Redirect Query Parameters Validated Against Open Redirects (http://youtube.com/)**
`Tested ?redirect=, ?next=, ?url=, ?returnTo= - no external 3xx Location reflection`